

VEILLE INFORMATIQUE

Sécurité des Applications Mobiles

Panorama des menaces, réglementations et bonnes pratiques

2025 – 2026

Élève	EL FARISSI Youssef
Classe	BTS SIO 2ème année – Lycée Chaptal, Quimper
Option	SLAM (Solutions Logicielles et Applications Métiers)
Sujet	Sécurité des Applications Mobiles

Résumé exécutif

Cette veille informatique analyse les évolutions majeures de la sécurité des applications mobiles entre le second semestre 2025 et le premier trimestre 2026. Elle couvre les bulletins de sécurité Android officiels (janvier à avril 2026), les nouvelles réglementations de la CNIL, les menaces émergentes (malware DarkSword sur iOS, trojans bancaires Android, adware), les statistiques de Kaspersky et Malwarebytes, les nouvelles exigences Google pour les développeurs, la mise à jour OWASP Top 10 2025, et les bonnes pratiques à adopter. Ce document est rédigé dans le cadre du BTS SIO en vue de l'épreuve orale de 2ème année.

SOMMAIRE

1. Introduction – Contexte et enjeux
2. Bulletins de sécurité Android (Jan–Avr 2026)
3. Nouvelles exigences Google pour les développeurs (2026)
4. Réglementation CNIL – Recommandations et contrôles
5. DarkSword – Exploit chain iOS découvert en 2026
6. Statistiques des menaces mobiles 2025 (Kaspersky / Malwarebytes)
7. OWASP Top 10 2025 – Mise à jour majeure
8. Tendances et menaces pour 2026
9. Bonnes pratiques pour les développeurs et les utilisateurs
10. Conclusion

1 Introduction – Contexte et enjeux

Les applications mobiles sont devenues indispensables dans notre quotidien : banque en ligne, messagerie instantanée, santé, travail à distance, paiement sans contact... En 2026, on recense plus de **6,8 milliards de smartphones actifs** dans le monde, et les applications mobiles représentent **70 % des interactions numériques** selon le rapport Strobex 2025. Cette omniprésence en fait une cible de choix pour les cybercriminels.

En 2025, les attaques sur mobile ont connu une accélération sans précédent. Les chercheurs de Kaspersky ont bloqué plus de **14 millions d'attaques Android** sur l'ensemble de l'année. Selon Malwarebytes, les malwares ciblant Android ont augmenté de **151 %** au premier semestre 2025 par rapport à l'année précédente. Le phishing par SMS a quant à lui bondi de **692 %** entre avril et mai 2025.

Pourquoi cette veille est-elle importante pour le BTS SIO ?

En tant que futur technicien ou développeur en systèmes d'information, la maîtrise des enjeux de sécurité mobile est indispensable. Les compétences attendues incluent la connaissance des réglementations (CNIL, RGPD), des normes (OWASP MASVS), des menaces actives et des outils de sécurisation. Cette veille couvre l'ensemble de ces aspects avec des sources officielles et récentes.

2 Bulletins de sécurité Android – Janvier à Avril 2026

Google publie chaque mois un bulletin de sécurité officiel pour Android. Ces bulletins recensent les vulnérabilités corrigées, classées par sévérité (Critique, Haute, Modérée, Faible). En 2026, Google a également modifié son modèle de publication du code source AOSP (Android Open Source Project) pour l'aligner sur un cycle trimestriel stable (T2 et T4).

Tableau récapitulatif des bulletins 2026

Mois	Date de publication	Niveau de correctif	Points clés
Janvier 2026	6 janvier 2026	2026-01-05	Correctifs Framework Android, composants système, kernel
Février 2026	2 février 2026	2026-02-05	Failles composants Google, correctifs Pixel spécifiques
Mars 2026	2 mars 2026	2026-03-05	Correctifs Wear OS, Android Automotive OS inclus
Avril 2026	1er avril 2026	2026-04-05	Correctifs composants Google, modifications AOSP Q2

Fonctionnement du système de correctifs Android

Chaque bulletin comporte **deux niveaux de correctifs** : le niveau du 1er du mois (correctifs partiels) et le niveau du 5 du mois (correctifs complets). Les appareils utilisant le niveau "2026-03-05" ou supérieur sont protégés contre toutes les failles documentées dans ce bulletin et les précédents. **Google Play Protect** est activé par défaut et surveille les applications potentiellement dangereuses, y compris celles installées en dehors du Play Store (sideloading).

Problème persistant : les appareils non mis à jour

Selon les données de 2026, **39 % des utilisateurs Android** tournent encore sous des versions antérieures à Android 13, donc sans accès aux derniers correctifs de sécurité. Côté tablettes, seulement **41 %** bénéficient d'un support actif. Un appareil non mis à jour depuis 3 mois présente des risques réels d'infection.

Source : <https://source.android.com/docs/security/bulletin/2026/2026-01-01?hl=fr>

Source : <https://source.android.com/docs/security/bulletin/2026/2026-02-01?hl=fr>

Source : <https://source.android.com/docs/security/bulletin/2026/2026-03-01?hl=fr>

Source : <https://source.android.com/docs/security/bulletin/2026/2026-04-01?hl=fr>

Source : <https://www.cyber.gc.ca/fr/alertes-avis/bulletin-securite-android-correctif-cumulatif-mensuel-mars-2026-av26-187>

3 Nouvelles exigences Google pour les développeurs Android (2026)

Depuis 2026, Google a introduit une série de mesures pour renforcer la confiance dans l'écosystème Android, notamment face à la multiplication des applications malveillantes distribuées hors du Play Store.

Vérification d'identité obligatoire pour tous les développeurs

À compter de 2026, Google exige une **vérification d'identité obligatoire** pour tout développeur souhaitant publier une application sur des appareils certifiés Google, qu'elle soit distribuée via le Google Play Store ou installée en sideloading. Cette mesure vise à réduire la présence d'applications malveillantes anonymes.

Déclaration de Tatyana Shishkova, chercheuse principale chez Kaspersky :

"L'obligation de vérification désormais annoncée pour tous les développeurs souhaitant proposer leurs applications sur des appareils certifiés Google représente une étape importante vers le renforcement de la sécurité Android."

Renforcement de Google Play Protect

- Désactivation automatique des autorisations d'applications jugées potentiellement dangereuses
- Réinitialisation automatique des permissions des applications inutilisées (depuis Android 11)
- Badges de vérification pour les développeurs gouvernementaux et les VPN sécurisés certifiés
- Notifications Chrome invitant à réactiver Play Protect si désactivé volontairement
- Isolation et restriction des comportements suspects d'applications en temps réel

Bilan Google Play 2025

Applications bloquées	1,75 million d'apps non conformes empêchées de publication (Google, fév. 2026)
Comptes développeurs bannis	80 000 comptes malveillants supprimés en 2025
Accès excessifs bloqués	255 000 apps empêchées d'accéder à des données sensibles
Faux avis supprimés	160 millions d'évaluations spam bloquées

Android 16 – Mode de protection avancée

Android 16 inaugure un **Mode de protection avancée** qui regroupe toutes les mesures de sécurité drastiques en un seul clic : désactivation de l'USB, interdiction du sideloading, bac à sable ultra-renforcé et verrouillage des paramètres de sécurité. Ce mode s'adresse en priorité aux journalistes, professionnels et utilisateurs à risque.

Source : <https://b2b-cyber-security.de/fr/mehr-google-app-security-aber-erst-ab-2026/>

Source : <https://www.infos-nantes.fr/android-2026-la-securite-renforcee-expliquee-simplement/>

Source : <https://www.onoff.gr/blog/fr/android/securite-android-2026-les-reflexes-essentiels-pour-proteger/>

4 Réglementation CNIL – Recommandations et contrôles

La Commission Nationale de l'Informatique et des Libertés (CNIL) est l'autorité française de protection des données personnelles. Elle joue un rôle central dans l'encadrement des applications mobiles en France et en Europe, au titre du **RGPD (Règlement Général sur la Protection des Données)**.

Recommandations CNIL – Avril 2025 (mises à jour)

En avril 2025, la CNIL a actualisé ses recommandations techniques pour les applications mobiles. Ces recommandations définissent le cadre minimal à respecter pour tout développeur ou éditeur d'application distribuée en France.

Domaine	Recommandation CNIL
Communications	Chiffrement obligatoire via TLS (Transport Layer Security) pour toutes les communications réseau
Stockage des clés	Utilisation du Hardware Keystore (Android) ou du Secure Enclave (Apple iOS)
Sauvegardes	Interdiction des sauvegardes non sécurisées des données sensibles
Authentification	Adapter le niveau d'authentification au niveau de risque de l'application
Normes	Respect minimum du niveau L1 des normes OWASP MASVS (Mobile Application Security Verification Standard)
Consentement	Obtention explicite du consentement avant toute collecte ou traitement de données
SDK tiers	Audit obligatoire des SDK tiers intégrés (trackers publicitaires, analytics...)
Permissions	Principe de minimisation : ne demander que les permissions strictement nécessaires

Plan de contrôle 2025 – 25 % des contrôles dédiés aux apps mobiles

En mars 2025, la CNIL a annoncé que **25 % de ses contrôles prévus en 2025** concerneraient les applications mobiles. Les cibles prioritaires sont les éditeurs qui :

- Utilisent des SDK tiers collectant des données sans consentement explicite
- Laissent des permissions trop larges ou non justifiées par le fonctionnement de l'app
- Ne respectent pas le principe de minimisation des données
- N'informent pas clairement les utilisateurs sur les traitements effectués

Webinaire CNIL – Janvier 2025

Le 31 janvier 2025, la CNIL a organisé un webinaire de sensibilisation pour rappeler les règles à respecter lors du développement d'applications. Elle y a notamment présenté les prescriptions de septembre 2024 et guidé les développeurs sur la conception d'applications conformes au RGPD.

Focus Pradeo – Analyse des recommandations CNIL (Février 2026)

L'entreprise Pradeo, leader européen de la sécurité mobile, a publié en février 2026 une analyse détaillée des recommandations CNIL. Elle souligne notamment la nécessité de définir clairement les rôles : éditeur, développeur, fournisseur de SDK, gestionnaire de store. Chaque acteur doit savoir s'il est **responsable de traitement, sous-traitant ou co-responsable**.

Source : <https://www.cnil.fr/sites/cnil/files/2025-04/recommandation-applications-mobiles-modifiee.pdf>

Source : <https://www.cnil.fr/fr/les-contrôles-de-la-cnil-en-2025>

Source : <https://www.cnil.fr/fr/revoir-le-webinaire-applications-mobiles-que-retenir-des-nouvelles-recommandations-de-la-cnil>

Source : <https://blog.pradeo.com/fr/focus-sur-les-recommandations-de-la-cnil-relatives-aux-applications-mobiles>

5 DarkSword – Exploit chain iOS découvert en 2026

■■ Alerte de sécurité majeure – Avril 2026

DarkSword est un exploit chain complet ciblant les iPhones sous iOS 18.4 à 18.6.2, découvert par les chercheurs de Lookout Threat Labs. Il a été attribué à un acteur de menace inconnu, probablement russe, désigné UNC6353 par Google.

Qu'est-ce que DarkSword ?

DarkSword est une **chaîne d'exploitation complète (full exploit chain)** et un outil de vol d'informations (infostealer) écrit en JavaScript. Il exploite plusieurs vulnérabilités pour établir une exécution de code privilégiée et accéder aux données sensibles de l'appareil.

Mécanisme d'attaque (Kill Chain)

1	Étape 1 – Point d'entrée L'attaque commence quand Safari charge un iframe malveillant intégré dans une page web compromise (technique "watering hole").
2	Étape 2 – Évasion du sandbox DarkSword exploite une faille WebContent pour sortir du bac à sable du navigateur.
3	Étape 3 – Élévation de privilèges Il utilise WebGPU pour s'injecter dans le processus mediaplayerd, obtenant des privilèges élevés.
4	Étape 4 – Exfiltration Une fois l'appareil compromis, le malware a accès illimité aux données professionnelles et personnelles.

Sites ciblés et victimes

Toutes les attaques observées ont ciblé des visiteurs de sites ukrainiens compromis : le site d'information *News of Donbas* (novosti.dn.ua) et le site officiel de la Septième Cour d'appel administrative d'Ukraine. Une infection a été confirmée le 12 février 2026 chez un employé d'un fabricant agroalimentaire en Ukraine.

Réponse d'Apple

Certaines des vulnérabilités exploitées par DarkSword ont été corrigées par Apple avec les patches "DarkSword" étendus à iOS 18.7.7 début avril 2026. Cela souligne l'importance cruciale de maintenir ses appareils iOS à jour, surtout dans un contexte professionnel.

Source : <https://www.lookout.com/threat-intelligence/article/darksword>

Source : <https://www.malwarebytes.com/blog/mobile/2025/12/android-threats-in-2025-when-your-phone-becomes-the-main-attack-surface>

6 Statistiques des menaces mobiles 2025 (Kaspersky & Malwarebytes)

Rapport annuel Kaspersky – Mobile Threat Report 2025

Kaspersky a publié en mars 2026 son rapport annuel sur les menaces mobiles pour 2025. Les chiffres sont alarmants et confirment une professionnalisation croissante des attaquants.

Total attaques bloquées	14 059 465 attaques Android bloquées sur l'année 2025
Nouveaux packages malveillants	815 735 nouvelles applications malveillantes détectées
Trojans bancaires	255 090 packages de trojans bancaires détectés (x4 vs 2024)
Q3 2025 seul	47 millions d'attaques bloquées au seul 3ème trimestre 2025
Adware	62 % de tous les malwares détectés en 2025 (famille MobiDash dominante)
Augmentation H1 2025	+29 % d'attaques vs H1 2024, +48 % vs H2 2024
Backdoor Keenadu	Backdoor préinstallée dans le firmware de certains appareils Android (Q4 2025)

Rapport Malwarebytes – Bilan 2025

Malwarebytes a également publié un bilan détaillé des menaces Android en 2025, révélant une escalade marquée au second semestre.

Malwares Android H1 2025	+151 % par rapport à l'année précédente
Spywares	+147 % ; pic x4 en février-mars 2025
SMS malware	+692 % entre avril et mai 2025 (campagnes de phishing fiscal)
Adware (2ème semestre)	+90 % des détections adware vs 1er semestre (MobiDash)
PUP (logiciels indésirables)	+75 % sur la même période

Lookout – Rapport Q3 2025 (publié mars 2026)

Lookout révèle dans son rapport Q3 2025 que **13 % des appareils mobiles d'entreprise** ont rencontré du contenu de phishing ou malveillant chaque trimestre. Plus de **71 000 applications malveillantes** ont été détectées sur des appareils d'entreprise au seul Q3 2025.

Les familles de malwares les plus actives en 2025-2026

Famille	Type	Plateforme	Impact
Triada	Trojan	Android	Vol de données, fraude publicitaire via apps messaging modifiées

MobiDash	Adware SDK	Android	Pop-ups intrusives ; +100 % de croissance en 2025
Mamont	Banking Trojan	Android	Vol de codes OTP et de données bancaires
SparkCat	Infostealer OCR	iOS/Android	Vol de phrases de récupération crypto par OCR (fév. 2025)
DarkSword	Exploit chain	iOS	Accès total à l'appareil via failles WebKit/WebGPU (2026)
Keenadu	Backdoor firmware	Android	Préinstallé en usine, accès à tous les processus

Source : <https://securelist.com/mobile-threat-report-2025/119076/>

Source : <https://www.malwarebytes.com/blog/mobile/2025/12/android-threats-in-2025-when-your-phone-becomes-the-main-attack-surface>

Source : <https://www.malwarebytes.com/blog/news/2025/06/android-threats-rise-sharply-with-mobile-malware-jumping-by-151-since-start-of-year>

Source : <https://www.vervali.com/blog/android-malware-statistics-2026-threat-landscape-ios-comparison-and-detection-trends/>

7 OWASP Top 10 2025 – Mise à jour majeure des vulnérabilités

L'OWASP (Open Worldwide Application Security Project) est une organisation internationale à but non lucratif qui publie des standards de référence en sécurité applicative. Le **Top 10 OWASP** est la liste des dix risques les plus critiques, mise à jour tous les deux ans. La version 2025 introduit **deux nouvelles catégories** et effectue plusieurs fusions importantes.

Ra ng	Cod e	Vulnérabilité	Statut 2025
1	A01	Contrôle d'accès défaillant	= (inchangé, 1er depuis 2021)
2	A02	Mauvaise configuration de sécurité	Montée (était A05 en 2021)
3	A03	Défaillances de la chaîne d'approvisionnement logicielle	NOUVEAU (extension de A06-2021)
4	A04	Échecs cryptographiques	Descente (était A02 en 2021)
5	A05	Injection	Descente (était A03 en 2021)
6	A06	Composants vulnérables et obsolètes	Descente
7	A07	Identification et authentification défaillantes	= (inchangé)
8	A08	Intégrité des données et logiciels	= (inchangé)
9	A09	Échecs de logging et d'alerte	= (inchangé)
10	A10	Mauvaise gestion des conditions exceptionnelles	NOUVEAU en 2025

Deux nouvelles catégories en 2025

A03 – Défaillances de la chaîne d'approvisionnement logicielle

Cette nouvelle catégorie étend la notion de "composants vulnérables" à l'ensemble du cycle de développement et de distribution du logiciel. Elle couvre les mises à jour mal validées, les modules compromis, les dépendances tierces non auditées et les outils de build infectés. Dans le contexte mobile, cela inclut les **SDK tiers** intégrés aux applications (analytics, publicité, paiement).

A10 – Mauvaise gestion des conditions exceptionnelles

Cette catégorie, entièrement nouvelle, couvre les erreurs de gestion d'exceptions, les états anormaux non anticipés et les comportements de "fail open" (l'application accorde l'accès en cas d'erreur au lieu de le refuser). Dans les applications mobiles, ce type de faille peut permettre un accès non autorisé à des fonctionnalités sensibles.

OWASP MASVS – Standard spécifique aux applications mobiles

L'**OWASP Mobile Application Security Verification Standard (MASVS)** est le référentiel spécifique aux applications mobiles. Il définit deux niveaux de sécurité :

- **Niveau L1 (requis par la CNIL)** : Contrôles de sécurité fondamentaux – chiffrement des communications, stockage sécurisé des données, authentification basique.
- **Niveau L2** : Défense en profondeur – protection contre la rétro-ingénierie, détection de root/jailbreak, intégrité du code.

Source : <https://owasp.org/Top10/2025/>

Source : <https://www.it-connect.fr/decouverte-du-nouveau-owasp-top-10-2025/>

Source : <https://www.fastly.com/fr/blog/new-2025-owasp-top-10-list-what-changed-what-you-need-to-know>

Source : <https://owasp.org/www-project-mobile-top-10/>

IA générative et phishing ultra-personnalisé

En 2026, les tentatives de phishing par SMS ou email ne ressemblent plus aux escroqueries d'antan (fautes d'orthographe, logos approximatifs). L'IA générative permet désormais de créer des messages **parfaitement personnalisés**, avec logos corrects, ton adapté et adresses d'expéditeurs légitimes. Les chercheurs d'OnOff.gr soulignent que ces attaques peuvent désormais imiter parfaitement les communications de votre banque.

Professionnalisation des attaques mobiles

Selon Malwarebytes, 2025 marque un tournant : les attaquants ne lancent plus des malwares isolés mais construisent de véritables **écosystèmes d'attaque** modulaires. Ils enchaînent des composants (droppers, modules de spyware, payloads bancaires) qui peuvent être combinés selon la cible.

Menaces ciblant les entreprises (BYOD)

En 2026, les équipes informatiques des entreprises font face à la gestion de parcs mixtes (Mac, smartphones, tablettes) dans un contexte de travail hybride. La **visibilité fragmentée** sur ces appareils est le principal risque selon Jamf : les entreprises qui ne peuvent pas voir l'état de leurs appareils mobiles ne peuvent pas les protéger efficacement.

Attaques NFC et paiement sans contact

Les **attaques par relais NFC** sont en forte hausse en 2025-2026. Ces attaques combinent le vol de données de paiement sans contact avec des transferts bancaires automatisés. On recense 34 familles actives de malwares bancaires ciblant 1 243 institutions financières dans 90 pays (rapport Vervali, mars 2026).

Sideloaded : la porte d'entrée principale des malwares

Selon le rapport Zimperium 2024 (projections 2025), **68 % des menaces mobiles** passent par des applications installées en dehors des stores officiels (sideloading), en particulier dans le secteur fintech. C'est précisément pourquoi Google a rendu obligatoire la vérification des développeurs en 2026.

Menaces sur les appareils connectés (IoT mobile)

En 2025, le botnet **Kimwolf** a spécifiquement ciblé les **Android TV boxes**, démontrant que la menace mobile s'étend désormais à tous les appareils sous Android, y compris les téléviseurs connectés, montres intelligentes (Wear OS) et systèmes embarqués (Android Automotive OS). Google publie d'ailleurs des bulletins de sécurité dédiés à chacune de ces plateformes.

Source :

<https://www.jamf.com/fr/blog/les-tendances-de-securite-2026-qui-affectent-les-equipes-informatiques-en-pleine-croissance/>

Source : <https://www.phoneinfo.fr/protection-smartphone-cyberattaques-2026>

Source : https://www.ecranmobile.fr/Tendances-2025-La-securite-mobile-face-a-de-nouvelles-menaces_a77345.html

Pour les développeurs – Checklist de sécurité (2025-2026)

Secure by Design	Intégrer la sécurité dès la conception (DevSecOps), pas en fin de cycle
Chiffrement	Chiffrer toutes les données sensibles (AES-256) en transit (TLS 1.3) et au repos
Authentification	Implémenter la MFA (Authentification Multi-Facteurs) pour les fonctions sensibles
Analyse de code	Utiliser des outils d'analyse statique (SAST) et dynamique (DAST) du code
Tests d'intrusion	Réaliser des pentests réguliers selon l'OWASP MASVS
SDK tiers	Auditer tous les SDK tiers ; bannir les SDKs avec trackers non consentis
Permissions	Appliquer le principe de moindre privilège pour les permissions système
Sessions	Gérer correctement les tokens de session (expiration, révocation)
Mises à jour	Maintenir les dépendances et bibliothèques à jour (supply chain)
Conformité RGPD	Obtenir le consentement explicite ; permettre la suppression des données

Pour les utilisateurs – Réflexes essentiels en 2026

- ■ **Mises à jour** : activer les mises à jour automatiques du système et des applications
- ■ **Éviter le sideloading** : n'installer que depuis le Play Store ou l'App Store officiels
- ■ **Permissions** : refuser toute permission non justifiée par la fonction de l'app
- ■ **Authentification** : activer la 2FA sur tous les comptes sensibles (banque, messagerie...)
- ■ **PIN / Biométrie** : utiliser un code PIN robuste (6+ chiffres) ou la reconnaissance biométrique
- ■ **Wi-Fi public** : utiliser un VPN (WireGuard ou IKEv2) sur les réseaux non sécurisés
- ■ **Phishing** : vérifier systématiquement l'expéditeur avant de cliquer sur un lien
- ■ **Antivirus mobile** : envisager une solution comme Bitdefender ou Kaspersky Mobile Security
- ■■ **Applications inutilisées** : désinstaller les apps non utilisées (permissions dormantes)
- ■■ **Sauvegardes** : sauvegarder régulièrement ses données dans un espace chiffré

Source :

<https://prometteursolutions.com/blog/fr/checklist-de-test-de-securite-des-applications-mobiles-guide-du-developpeur/>

Source : <https://blog.digitalcook.fr/securite-des-applications>

Source : <https://www.webxperit.fr/blog/securite-applications-mobiles-2025>

Cette veille informatique démontre que la sécurité des applications mobiles est un domaine en **constante et rapide évolution**. Entre la découverte de DarkSword sur iOS, l'explosion des trojans bancaires Android (+4x en 2025), les nouvelles exigences Google et le renforcement réglementaire de la CNIL, le paysage de la menace mobile ne laisse aucune place à la négligence.

Trois grandes tendances se dégagent pour 2026 :

La réglementation se renforce

La CNIL contrôle activement les applications (25 % des contrôles en 2025), et Google impose la vérification d'identité des développeurs. La conformité n'est plus optionnelle.

Les attaques se professionnalisent

Les malwares mobiles sont désormais organisés en écosystèmes modulaires, assistés par l'IA, et capables de contourner les protections des OS modernes (ex. DarkSword sur iOS 18).

La défense doit être proactive

L'approche "Security by Design" et le respect des normes OWASP MASVS sont indispensables. Les mises à jour régulières restent le moyen le plus efficace pour 78 % des intrusions (qui exploitent des failles déjà corrigées).

En tant que futur professionnel de l'informatique (BTS SIO), il est essentiel de maîtriser ces enjeux pour conseiller efficacement les entreprises, développer des applications sécurisées et accompagner les utilisateurs dans l'adoption de bonnes pratiques numériques.